Journal des décisions

2026-10-04 — Architecture : monolithe modulaire
- Décision : un seul backend NestJS découpé en modules, une seule base PostgreSQL.
- Raison : projet mené seul, charge faible en moyenne ; les microservices
  ajouteraient de la complexité inutile.

2026-10-04 — Technologies
- Frontend : React + TypeScript + Vite.
- Backend : NestJS, système de modules CJS (CommonJS) avec Jest.
- Base de données : PostgreSQL, lancée avec Docker Compose en local.
- Raison pour CJS : plus de documentation et d'exemples, et le code proposé par
  les assistants d'IA y est plus souvent compatible.

2026-10-04 — Pas de module de suivi externe (@nestjs/observe)
- Décision : ne pas utiliser @nestjs/observe, installé automatiquement par le
  générateur de projet puis retiré.
- Raison : il envoie des données de suivi vers un service tiers ; la plateforme
  doit garder la maîtrise de ce qui sort du serveur.

2026-10-04 — Anonymat des évaluations
- Décision : deux espaces de stockage séparés, sans clé commune.
  - Registre de participation : qui a voté (sans la réponse).
  - Urne : ce qui a été voté (sans l'identité).
- Un jeton à usage unique, sans identité, autorise le dépôt dans l'urne.
- Rôles de base de données distincts pour l'écriture dans chaque espace.
- Résultats affichés seulement à partir de 5 répondants et après la clôture.
- Raison : l'anonymat doit être vérifiable, pas seulement promis.

2026-10-04 — Périmètre du MVP
- Inclus : comptes et imports CSV, évaluation anonyme, cahier de texte,
  résultats enseignant, synthèse à l'écran.
- Reporté en version 2 : double authentification, exports Word et Excel,
  rappels automatiques, SMS, comparaisons entre semestres.

2026-10-04 — Hébergement
- Décision : serveur et domaine ouverts au nom de l'ENP (crédits du pack
étudiant utilisés pendant la phase de test).
- Raison : la plateforme doit survivre à mon statut d'étudiant.
- À confirmer avec l'ENP.

2026-10-04 — Outils d'IA
- Figma : maquettes. Bolt.new : écrans de l'interface. Jules : tâches ciblées,
  dépôt privé, relecture de chaque pull request.
- Anonymat, authentification et droits d'accès : écrits par moi, avec relecture.
- Aucune vraie donnée d'étudiant dans les outils d'IA.

À valider avec l'ENP
- Référent à la Scolarité et accord écrit de la Direction.
- Authentification des étudiants (matricule + mot de passe).
- Données de test disponibles (UE, inscriptions, affectations).
- Département pilote et date de la campagne.

2026-10-04 - Mots de passe et acces a la base

Decision : hachage des mots de passe avec argon2id (bibliotheque @node-rs/argon2) ; requetes SQL directes avec le module pg, sans ORM, et
fichiers SQL numerotes dans infra/sql.

Raison : un outil de moins a apprendre en travaillant seul ; la separation
entre le registre de participation et l'urne reste visible ligne par ligne.

2026-10-04 - Jeton de connexion

Decision : jeton d acces JWT signe (HS256) de 15 minutes, produit avec la
bibliotheque jsonwebtoken ; un secret distinct par usage (acces, rafraichissement,

vote). Meme message d erreur pour un mauvais mot de passe et un identifiant inconnu.

Raison : jsonwebtoken fonctionne independamment de la version de NestJS (la compatibilite de @nestjs/jwt avec NestJS 12 n a pas ete verifiee) ; le message unique evite de reveler quels matricules existent.

A faire : jeton de rafraichissement, verrouillage apres echecs, HTTPS en production.

2026-10-05 - Roles et protection des routes

Decision : decorateur @Acces('role1', 'role2') qui applique la verification du jeton puis des roles (un seul des roles indiques suffit). Les noms de roles sont dans un type unique (src/auth/roles.ts).

Raison : une faute de frappe sur un role est detectee a la compilation ; l'ordre des portiers est garanti.

Limites connues : les roles sont lus dans le jeton, donc un changement de role n'agit qu'apres expiration du jeton (15 min) ; une route sans @Acces est publique, a corriger par une protection par defaut avant le MVP.

A faire : supprimer le DiagnosticController avant la production.

2026-10-05 - Verrouillage et protection par defaut

Decision : 5 echecs de connexion consecutifs verrouillent le compte 15 minutes (reponse 429, mot de passe non teste pendant le verrouillage). Toute route exige un jeton, sauf celles marquees @Public() (connexion, sante).

Raison : limiter les attaques par essais repetes ; supprimer le risque d'oublier de proteger une route.

Limites connues : un attaquant qui connait un matricule peut verrouiller ce compte (a limiter par une limitation de debit par adresse au

deploiement) ;
le message 429 revele que le compte existe ; un jeton deja emis reste
valable 15 minutes ; les echecs sur identifiants inexistants ne sont pas comptes.

A faire : fonction de deverrouillage par la Scolarite ; jeton de rafraichissement et expiration apres 30 min d'inactivite (etape 5.6).

2026-10-05 - Session et jeton de rafraichissement

Decision : jeton d'acces de 15 min + jeton de session aleatoire dans un cookie
HttpOnly, SameSite=Strict, limite au chemin /api/v1/auth, Secure en production.
La base ne garde que l'empreinte SHA-256. Rotation a chaque renouvellement ;
si un ancien jeton revient, toute la session est revoquee.
Inactivite : 30 min
sans renouvellement ; duree maximale : 8 h.

Raison : le jeton de session n'est pas lisible par JavaScript (limite le vol par
faille XSS) et il est revocable cote serveur.

Limites connues : un jeton d'acces deja emis reste valable jusqu'a 15 min apres
une deconnexion ; la coupure par inactivite survient entre 15 et 30 min de
vraie inactivite (le delai court depuis le dernier renouvellement) ;
deux renouvellements simultanes (deux onglets) declenchent la detection de vol ;
les lignes expirees ne sont pas encore purgees ; CORS non configure.

A faire : le frontend doit renouveler un seul jeton a la fois (semaine 5) et
appeler /auth/refresh au chargement de la page ; purge periodique de la table ;
revoquer toutes les sessions lors d'un changement de mot de passe.

2026-10-05 - Referentiels : UE et cours

Decision : schema ref. L UE (ref.ue) est le catalogue ; le cours (ref.course = UE x formation x annee x semestre) est l unite evaluee. Le course_id du registre de participation et de l urne designe ref.course.id. Inscriptions, affectations et delegues se rattachent a identity.users.

Raison : une meme UE peut etre dispensee chaque annee et dans plusieurs formations ; evaluer le cours evite de melanger les promotions.

Limites connues : pas encore de cle etrangere entre evaluation.participation_ledger et ref.course (a ajouter apres les donnees de test) ; aucune archive annuelle (V2).

Anonymat : aucune table de ballot ne reference ref ni identity.

2026-10-05 - Donnees de test fictives

Decision : infra/sql/dev-donnees-test.sql cree un campus, une formation, 2 UE, 2 cours (INF501 avec 5 inscrits, INF502 avec 3) et 8 comptes TEST-xxxx sans mot de passe. Le fichier est relancable et reserve au developpement.

Raison : disposer de donnees realistes pour tester les routes, l import CSV et le seuil de 5 repondants, sans aucune donnee reelle.

Regle : ne jamais executer ce fichier sur le serveur de production.

2026-10-06 - Questionnaire et campagnes

Decision : l'unite evaluee est ref.course (une UE offerte pour un programme, une annee et un semestre). Dans l'API, le champ ueId contient ref.course.id. Une campagne couvre un departement, une annee et un semestre (une seule par trio) et fige la version du questionnaire a sa creation. Cycle : brouillon, ouverte, close, restituee. Les etudiants n'y accedent que si elle est ouverte

et dans sa periode. Les cles etrangeres du registre et de l'urne sont ajoutees ;
l'urne ne reference jamais un etudiant.
Raison : l'offre d'une UE varie selon le programme et le semestre ; une campagne par trio correspond a la grille de synthese par semestre.
Limites connues : "terminee" signifie que la participation est enregistree
(jeton emis), pas qu'un bulletin a ete depose ; la cloture est manuelle (pas de
cloture automatique a la date de fin) ; aucun role "chef de departement"
n'est lie a un departement (table a creer en phase 4) ; ref.ue et ref.course
n'ont pas de volumes horaires CM/TD/TP (necessaires au cahier de texte) ;
le nom du champ ueId est trompeur (il designe un course).
A faire : jeton de vote (6.2), depot dans l'urne et roles de base de donnees
distincts (6.3), resultats et seuil (6.4).

2026-10-06 - Jeton de vote

Decision : POST /evaluations/{ueId}/jeton (ueId = ref.course.id) verifie
l'inscription, la campagne ouverte et sa periode, et enregistre la participation dans le registre en UNE requete atomique (contrainte d'unicite).
Il remet un jeton signe (HS256, secret BALLOT_TOKEN_SECRET distinct des autres)
de 60 minutes dont le contenu est typ, cid, ue, jti et exp : aucune identite
et aucune heure d'emission. Reponse sans mise en cache.
Raison : l'etudiant est identifie au moment de l'emission, jamais au depot ;
une seule requete evite le double vote en cas de demandes simultanees.
Limites connues : un etudiant qui perd son jeton (onglet ferme) ne peut plus
voter pour cette UE, car sa participation est deja enregistree ; une reinitialisation manuelle par la Scolarite n'est pas prevue, car elle
permettrait un double vote si le bulletin a deja ete depose ; le

jeton peut
etre transmis a un tiers ; les jetons deja utilises ne sont pas encore
suivis (anti-rejeu : etape 6.3) ; le serveur web ne devra journaliser ni les
adresses ni les corps des requetes sur /ballots.
A faire : depot dans l'urne et roles de base de donnees distincts (6.3).

2026-10-07 - Depot dans l'urne et roles de base de donnees

Decision : POST /ballots est publique et n'accepte que le jeton de vote ; le
controleur ne recoit que le corps (ni IP, ni en-tetes). Le depot est une seule
transaction : verification de la campagne et des criteres, consommation du jeton
(table used_tokens, anti-rejeu), ecriture du bulletin, des reponses et des
commentaires. Trois roles : ballot_app (depose, ne lit ni le registre ni les
identites), app_main (tout sauf l'urne), et enp (super-utilisateur, reserve a
l'administration et jamais utilise par l'application). L'application refuse de
demarrer si l'un des deux roles a trop de droits.
Raison : l'anonymat doit etre verifiable dans la base, pas seulement dans le code.
Limites connues : le super-utilisateur peut tout croiser (son acces doit etre
restreint et trace) ; l'ordre physique des lignes et les numeros de transaction
pourraient aider a rapprocher registre et urne (a attenuer par un reordonnancement
de la table des bulletins a la cloture, etape 6.4) ; un depot simultane a la
cloture peut etre accepte ou refuse ; le jeton peut etre confie a un tiers ;
la table used_tokens n'est pas purgee ; le serveur web ne devra journaliser ni les
adresses ni les corps des requetes sur /ballots.

A faire : lecture des resultats et moderation par un acces dedie a l'urne via des vues sans identite (6.4 et 6.5) ; configuration du serveur web au deploiement.

2026-10-07 - Resultats et lecture de l'urne

Decision : troisieme role results_app, en lecture seule sur l'urne (ni registre, ni identites, ni referentiels). Les droits d'acces et les referentiels sont verifies par app_main ; les chiffres sont lus par results_app. Seuil de 5 bulletins applique avant tout calcul. Moyennes calculees sur toutes les notes (sans avis exclu), moyenne de section sur toutes les notes de la section. Commentaires : uniquement les valides, dans un ordre aleatoire. Resultats lisibles seulement pour une campagne close ET preparee. La preparation (fonction SQL evaluation.preparer_resultats, SECURITY DEFINER) a lieu a la premiere consultation, au moins 2 minutes apres la cloture : elle melange physiquement les lignes de la campagne (ordre de depot et numeros de transaction effaces) et purge les jetons expires. L'application refuse de demarrer si les trois roles ont trop de droits.

Raison : l'enseignant doit pouvoir lire ses resultats sans que personne puisse relier un bulletin a un etudiant ; le delai evite qu'un depot en cours echappe au melange.

Limites connues : le chef de departement n'a pas de route (aucune table ne le rattache a un departement) ; le super-utilisateur peut tout lire et la fonction de preparation s'execute avec ses droits ; les lignes effacees restent dans les fichiers jusqu'au nettoyage (VACUUM FULL optionnel) ; un seuil de 5

n'empeche pas
l'inference quand tous les repondants ont donne la meme note ; le texte libre
peut identifier son auteur ; les campagnes n'apparaissent dans la liste qu'apres
le delai de 2 minutes ; la consultation n'est pas encore journalisee dans une
table d'audit (seulement dans les logs) ; commentaires non visibles tant que la
moderation (6.5) n'est pas faite.
A faire : moderation des commentaires (6.5) ; table de rattachement du chef de
departement ; journal d'audit des consultations ; envisager un seuil plus eleve.

2026-10-08 - Moderation, restitution et journal d'audit

Decision : la moderation passe par la fonction SQL evaluation.moderer_commentaire
(SECURITY DEFINER) qui ne modifie que la colonne statut, jamais le texte, et ecrit
la trace dans le meme appel. Moderation reservee a la Scolarite, possible apres la
cloture ET la preparation de l'urne, y compris apres la restitution. Les
commentaires d'une UE sous le seuil de 5 bulletins ne sont ni proposes ni
moderables. Identifiant public d'un commentaire opaque (uuid.type), ordre aleatoire,
sans date ni auteur. Journal d'audit (schema audit) : ajout seul pour l'application,
jamais le texte des commentaires. Restitution (article 77) : une par campagne,
definitive, publiee en une seule requete (statut, textes, trace) ; les etudiants la
lisent selon leurs inscriptions, sans toucher au registre ni a l'urne.
Raison : personne, pas meme la Scolarite, ne doit pouvoir reecrire un commentaire ;
toute decision doit laisser une trace fiable ; la restitution est

une obligation du
reglement.

Limites connues : l'application peut ajouter de fausses lignes au journal (elle ne peut ni les modifier ni les supprimer, mais le super-utilisateur le peut) ; un commentaire valide puis masque reste vu par l'enseignant jusqu'au masquage ; la Scolarite voit tous les commentaires des UE au-dessus du seuil avant moderation ; le masquage d'un texte a la main est le seul filtre contre les propos identifiants ; la restitution est du texte libre non verifie contre les resultats reels ; la date de publication est visible des etudiants ; aucune route de consultation du journal.

A faire : route de consultation du journal (admin) ; table de rattachement du chef de departement ; imports CSV ; route des departements et tableau de bord de la Scolarite.